1. Depuración de requisitos

1.1 Cambios realizados

De los 14 requisitos iniciales, 2 se conservan con mejoras o controles, 8 se modifican y 4 se eliminan y teniendo un total de 22. Estos requisitos reducen filas y llamadas sin tratar datos de salud.

Objetivo del sistema: Permitir que el afiliado o un representante de este, busque disponibilidad, reserve, cancele y reprograme turnos de atención del IESS por web y móvil y también reciba notificaciones de cambios.

¿Qué hará el sistema?

Gestión de turnos en general. Cosas como la información clínica no se contemplan, la historia clínica y a los profesionales de salud que tratan al paciente tampoco (LOPDP, art. 30). El sistema solo da un turno con su lugar y especialidad.

Escenario: El escenario contempla 50.000 cuentas, 3.000 usuarios simultáneos y 120 funcionarios distribuidos entre atención al usuario, personal médico, administración y soporte.

Responsable de los datos: El IESS, como entidad del sector público (art. 225 de la Constitución). Esto activa dos obligaciones de diseño: designar delegado de protección de datos (LOPDP, art. 48.1) y aplicar el mecanismo gubernamental de seguridad de la información, hoy el EGSI 3.0 (LOPDP, art. 38).

Criterios y justificativos

Los cambios se basaron en lo siguiente:

1. **La finalidad de los datos: si** se tratan para finalidades determinadas y explícitas (LOPDP, art. 10 d).
2. **Minimizar y limitar:** si algo es lo mínimo necesario y no es excesivo (art. 10 e y f).
3. **Riesgo:** Uno de los más importantes se analiza si introduce una vulnerabilidad o amplía el impacto, en base a un análisis de riesgos (arts. 37, 40 y 41).

4. **Servicio:** Saber si además de ser seguro sigue cumpliendo el objetivo de reducir filas y llamadas.

El diseño aplica protección de datos desde el diseño y por defecto (art. 39). No implementarla sería una infracción leve (art. 67.2), y no implementar medidas técnicas y organizativas sería grave (art. 68.1).

1.2 Cambios realizados

Los requisitos I03, I04, I05, I14 no cumplen con los criterios definidos anteriormente por lo que se eliminaron; los 8 modificados son correctos, pero como estaban inicialmente pueden generar vulnerabilidades o daños que pueden llegar a ser masivos.

ID	Solicitud del cliente	Decisión	Justificación técnica	Referencia	Requisito definitivo

ID	Solicitud del cliente	Decisión	Justificación técnica	Referencia	Requisito definitivo
I01	Buscar turnos por especialidad, establecimiento y fecha; reservar, cancelar y reprogramar citas.	**Conservar** con reglas	Son las bases del sistema, las reglas son necesarias para evitar acaparamiento de cupos y reservas duplicadas por la cantidad de usuarios (3.000 usuarios)	Art. 10 f (proporcionalidad)	RF-03 a RF-06, RS-06
I02	Solicitar nombres, cédula, fecha de nacimiento, correo y teléfono.	**Modificar**	Correo verificado **obligatorio** que sirve para confirmar control de la cuenta y para notificaciones. Fecha de nacimiento solo como dato de verificación, no como secreto debido a la facilidad de adivinar. Teléfono propio opcional	Art. 10 e (minimización)	RF-01
I03	Exigir empleador, cargo, sueldo, cuenta bancaria y copia del contrato de trabajo para reservar cualquier turno.	**Eliminar**	No son necesario para un turno, ademas la condición de afiliado la confirma el servicio de I10. Ademas esto dejaría fuera a jóvenes o personas sin empleo y ademas podria dar pie a fraude	Art. 10 d, e y f	RS-03
I04	Solicitar diagnósticos, antecedentes, medicamentos, alergias y resultados de laboratorio antes de mostrar disponibilidad.	**Eliminar**	Mostrar disponibilidad no requiere datos de salud. Para 50.000 cuentas sería tratamiento a gran escala de categorías especiales, con evaluación de impacto obligatoria, y multiplicaría el impacto de cualquier brecha ademas de un coste alto de recursos.	Arts. 25 c, 26, 30, 31.2 y 42 b	RS-03

ID	Solicitud del cliente	Decisión	Justificación técnica	Referencia	Requisito definitivo
I05	Preguntar religión, afiliación política y composición familiar para personalizar la atención.	**Eliminar**	Religión y filiación política no tienen sentido en un turno o personalizacion. La composición familiar puede funcionar en caso de que existan detalles pero la representación se resuelve con I06 rediseñado	Arts. 4 (datos sensibles), 10 d y 26	RS-03
I06	Permitir que una persona gestione citas de otra ingresando únicamente su número de cédula y fecha de nacimiento.	**Modificar**	Ambos datos se obtienen con facilidad (fotocopias, redes, robo), con eso cualquiera podría cancelar o reservar sin autorización real. Presentar la cédula seria una solución, pero no basta porque la Superintendencia alertó sobre los riesgos de entregar copias del documento (Primicias) y almacenar imágenes de cédulas crea un activo para suplantación. Se sustituye por una representación con consentimiento o verificación presencial, alcance, caducidad y revocación(como en otro servicios municipales).	Arts. 8 (consentimiento revocable), 18.1 (representante acreditado), 21 y 24 (niñas, niños y adolescentes)	RF-07, RF-08, RF-09, RS-07
I07	Utilizar cédula y una contraseña inicial formada por la fecha de nacimiento; dejar el cambio como opcional.	**Modificar**	Una contraseña derivada de un dato conocido es adivinable y al ser opcional el cambio permanecería. Se usaria el patrón de activación por correo usado por servicios públicos como el Registro de la Propiedad o el PAM de Quito, con contraseña propia y segundo factor. FirmaEC por ejemplo no se exige porque elevaría la barrera de acceso sin necesidad	Art. 10 j (seguridad), art. 37	RF-01, RF-02, RS-01

ID	Solicitud del cliente	Decisión	Justificación técnica	Referencia	Requisito definitivo
I08	Permitir que recepción, médicos, administradores y soporte visualicen todos los expedientes y turnos.	**Modificar**	Acceso total viola mínimo privilegio y convierte a cada una de las 120 cuentas en una puerta a todos los datos (riesgo de insider y de cuenta comprometida). Se definen roles con alcance por función y lugar	Arts. 10 g (confidencialidad), 38 (mecanismo gubernamental: EGSI 3.0)	RS-02, RF-11
I09	Enviar por SMS y correo la especialidad, el diagnóstico registrado y un enlace directo para abrir la información sin iniciar sesión.	**Modificar**	El diagnóstico y la especialidad revelan salud y el correo puede verse en pantallas bloqueadas o reenviarse ademas un enlace sin sesión es una credencial en texto plano que cualquiera con el mensaje acceder. Se enviaría un resumen por correo con un enlace al inicio de sesión y otro a instructivos	Arts. 10 e y g, 30	RF-10
I10	Conectar la aplicación con un servicio de validación de afiliación y con el sistema de disponibilidad de citas.	**Conservar** con controles	Imprescindible pero el riesgo está en confiar en un tercero o caer cuando él cae.	Art. 10 h (calidad y exactitud), 37.2	RF-12, RS-04
I11	Registrar consultas y modificaciones incluyendo contraseñas, tokens y contenido completo de las solicitudes para facilitar el soporte.	**Modificar**	Un log con secretos es una segunda base sensible y permite suplantar a cualquiera que aparezca en él, lo que destruye el no repudio que la auditoría debería dar. Se registran los eventos estructurados sin secretos	Arts. 10 j y k (responsabilidad proactiva), 43 (reconstruir la brecha en 5 días)	RS-05

ID	Solicitud del cliente	Decisión	Justificación técnica	Referencia	Requisito definitivo
I12	Utilizar una computadora de oficina con 8 GB de RAM como servidor de aplicación y base de datos.	**Modificar**	Punto único de fallo, sin separación entre aplicación y datos y sin capacidad para 3.000 concurrentes. Se propone una infraestructura modesta basada en un presupuesto público	Art. 37.2 y 37.3 (disponibilidad y resiliencia)	RNF-01
I13	Ofrecer atención continua, pero realizar mantenimiento diario de dos horas sin permitir reservas durante ese período.	**Modificar**	Es contradictorio y retira el servicio 60 h al mes. Se propone despliegue sin corte y una ventana semanal en solo lectura (sección 1.4)	Art. 37.2	RNF-02
I14	Conservar todos los datos indefinidamente y entregarlos a un proveedor externo para entrenar un asistente de inteligencia artificial.	**Eliminar**	Un asistente de IA no forma parte de la gestión de turnos. Conservar sin plazo y ceder datos a un tercero para otra finalidad no tiene una base legal	Arts. 10 d e i, 33 y 34; usar datos para fines distintos o cederlos sin requisitos es infracción grave (art. 68.2 y 68.3); Res. SPDP-SPD-2026-0009-R (IA) y 2026-0004-R (transferencias)	RS-08

Todas las citas de la LOPDP corresponden al texto vigente con la reforma del R.O. 5.º Supl. 290 de 22-may-2026 (texto consolidado).

1.3 Requisitos definitivos

Funcionales

ID	Requisito definitivo	Origen
RF-01	El sistema debe registrar al afiliado con cédula (con verificación), nombres, fecha de nacimiento y correo electrónico **obligatorio**; teléfono opcional. La cuenta se activa solo mediante un enlace de un solo uso enviado al correo, con el que el usuario fija su propia contraseña	I02, I07
RF-02	El sistema debe permitir iniciar sesión con cédula y contraseña, y con segundo factor TOTP cuando esté activado (obligatorio para funcionarios). Debe permitir cerrar sesión en todos los dispositivos	I07
RF-03	El sistema debe permitir buscar turnos disponibles por especialidad, establecimiento y fecha, consultando siempre la disponibilidad.	I01
RF-04	El sistema debe permitir reservar un turno disponible, con un máximo de un turno activo por titular y especialidad, garantizado también por una restricción en la base de datos	I01
RF-05	El sistema debe permitir cancelar un turno, previa confirmación que muestre titular, especialidad, fecha y hora y el cupo liberado vuelve a la disponibilidad de inmediato	I01
RF-06	El sistema debe permitir reprogramar un turno **una vez**, hasta 24 h antes, como operación atómica (se toma el nuevo cupo y se libera el anterior en la misma transacción)	I01
RF-07	El afiliado adulto debe poder otorgar a otra cuenta una representación con alcance (ver, reservar, cancelar, reprogramar, recibir notificaciones) y vigencia máxima de 12 meses, y revocarla en cualquier momento	I06
RF-08	La representación de menores y de personas con capacidad restringida debe ser verificada por un funcionario de atención con el documento que la acredita (patria potestad, tutela, curaduría o poder)	I06
RF-09	El titular debe poder consultar quién lo representa, con qué alcance y qué acciones se hicieron en su nombre, además cada reserva, cancelación o reprogramación hecha por un representante se le notifica por correo	I06
RF-10	El sistema debe enviar al correo verificado un resumen de cada reserva, cancelación, reprogramación o cambio del IESS con fecha, hora, establecimiento y código de turno, sin especialidad ni diagnóstico, con un enlace a la página de inicio de sesión (sin token) y otro a instructivos públicos	I09

ID	Requisito definitivo	Origen
RF-11	El personal debe disponer de funciones según su rol: atención gestiona turnos presenciales y verifica representaciones de su establecimiento; el médico ve su agenda del día; administración configura agendas y ve reportes agregados; soporte ve el estado técnico	I08
RF-12	El sistema debe validar la afiliación al reservar y sincronizar cupos con la agenda del IESS; si un servicio no responde, debe mostrar la disponibilidad conocida, impedir confirmar reservas y explicar al usuario que lo intente más tarde (modo degradado)	I10

Para la seguridad

ID	Requisito definitivo	Origen
RS-01	Contraseñas de al menos 12 caracteres, comparadas contra una lista de contraseñas comunes y filtradas, almacenadas con un algoritmo de hash resistente (Argon2id). Enlace de activación o recuperación de un solo uso, válido 60 min y guardado como hash. Bloqueo progresivo tras intentos fallidos por cuenta y por IP. Reautenticación antes de cambiar correo, contraseña, segundo factor o representantes	I07
RS-02	Control de acceso por rol y verificado en el servidor en cada solicitud y sobre cada objeto también denegación por defecto, además, ningún rol accede a todos los datos y cada consulta de datos de un afiliado por un funcionario queda auditada	I08
RS-03	El sistema no debe contener campos, tablas ni formularios para datos laborales, bancarios, de salud, religión o afiliación política	I03, I04, I05
RS-04	Las integraciones usan credenciales de servicio rotadas, TLS, validación de esquema de cada respuesta, tiempos de espera cortos, reintentos limitados y corte automático (circuit breaker); el sistema solo guarda el resultado de la validación (afiliado sí/no y fecha)	I10
RS-05	Auditoría estructurada de eventos: actor, "en nombre de" (si hay representación), acción, recurso, fecha y hora, origen, resultado e identificador de correlación. Nunca contraseñas, tokens, códigos ni cuerpos de solicitud con cédula enmascarada. Almacén separado, de solo anexado, con encadenamiento de hash, solo lectura para el rol auditor y retención definida.	I11
RS-06	Protección contra abuso: límites de solicitudes por cuenta e IP, máximo de turnos activos (RF-04), tope de 10 representados por cuenta con alerta, respuestas generales que no revelen datos	I01, I06

ID	Requisito definitivo	Origen
	específicos.	
RS-07	Los documentos aportados para verificar una representación se eliminan al verificarla (o a los 7 días si no se verifica). Solo se conserva quién verificó, cuándo y qué tipo de documento	I06
RS-08	Cada tipo de dato tiene plazo de conservación definido. Se prohíbe ceder datos a terceros fuera de los encargados del tratamiento con contrato ycualquier estadística se produce agregada y anonimizada	I14

No funcionales

ID	Requisito definitivo	Origen
RNF-01	Infraestructura separada por capas (proxy, aplicación, base de datos), con al menos dos nodos de aplicación, base de datos con réplica en espera y backups fuera del servidor principal, dimensionada para 3.000 usuarios simultáneos (Parte 3)	I12
RNF-02	Disponibilidad objetivo de 99,5 % mensual fuera de la ventana programada. Despliegues sin corte; una ventana semanal de hasta 2 h en modo solo lectura, domingo de 01:00 a 03:00, anunciada con 72 h de anticipación y usada solo cuando una tarea de base de datos lo exija	I13

1.4 Reglas de negocio y justificación de valores

Cada número de los requisitos responde a un riesgo concreto; ninguno se fija por costumbre. Los valores marcados como supuesto se validarán con las mediciones de la Parte 3.

Turnos (RF-03 a RF-06)

Regla	Valor	Justificación
Turnos activos por titular y especialidad	1	Impide acaparar y revender cupos de un recurso limitado. Se aplica aunque reserve un representante, para que no sirva como vía de evasión. Se refuerza con una restricción de unicidad en la base de datos, de modo que ni un error de código ni dos solicitudes simultáneas creen un segundo turno
Horizonte de reserva	Hasta 30 días (supuesto: la agenda publicada)	No se ofrecen cupos que la agenda del IESS aún no confirma
Cancelación sin restricción	Hasta 24 h antes	Da tiempo para que otro afiliado tome el cupo y para notificar el cambio

Regla	Valor	Justificación
Cancelación tardía	Entre 24 h y la hora del turno, permitida	Se rechazó exigir una semana: quien enferma o no puede asistir simplemente faltaría, y un cupo no liberado se pierde. Una cancelación tardía siempre es mejor que una inasistencia. Se registra como tardía, sin sanción
Reprogramación	1 vez por turno, hasta 24 h antes, atómica	Limita el uso de reprogramaciones sucesivas para "guardar" un cupo. La atomicidad evita quedar sin turno si el nuevo cupo se agota en medio de la operación
Inasistencias	3 sin cancelar en 90 días → el siguiente turno requiere confirmación en la app 48 h antes; si no se confirma, se libera	Reduce cupos perdidos **sin bloquear el acceso a la salud** (derecho del art. 32 de la Constitución): nunca se impide reservar, solo se pide confirmar

Representación (RF-07 a RF-09)

Regla	Valor	Justificación
Parentesco	Dato descriptivo, nunca permiso	"Madre" o "cónyuge" no prueban autorización; el permiso vive solo en el alcance concedido
Vigencia por consentimiento	Máximo 12 meses, renovable	Una autorización sin fecha de fin sobrevive a cambios de relación (separaciones, conflictos) y queda olvidada
Menores de 15 años	Representante legal verificado por un funcionario; vigencia hasta los 15 años	Las niñas, niños y adolescentes menores de 15 ejercen sus derechos mediante su representante legal (LOPDP, art. 24)
Adolescentes de 15 a 17 años	Pueden tener cuenta propia; la representación de un padre o madre requiere también su aceptación	Desde los 15 años pueden consentir el tratamiento de sus datos y ejercer sus derechos directamente (arts. 21 y 24). Se plantea como pregunta al cliente (1.6)
Representados por cuenta	Tope de 10, con alerta al superar 5	Cubre familias numerosas y cuidadores; por encima, el patrón corresponde a un tramitador
Documentos de verificación	Se eliminan al verificar o a los 7 días	Una base de imágenes de cédulas y partidas es un activo valioso para suplantación; tras verificar, basta el registro de quién verificó y qué

Autenticación y sesión (RS-01)

Regla	Valor	Justificación
Longitud mínima de contraseña	12 caracteres + lista de comunes y filtradas	La longitud y el rechazo de contraseñas conocidas frenan diccionario y relleno de credenciales mejor que reglas de complejidad que llevan a patrones predecibles
Enlace de activación o recuperación	Un solo uso, 60 min, guardado como hash	Si el correo se filtra después, el enlace ya no sirve; si la base se filtra, los enlaces no son utilizables
Intentos fallidos	Espera progresiva por cuenta tras 5 fallos (1, 5, 15 min) y límite por IP	Un bloqueo permanente permitiría a un atacante dejar sin acceso a la víctima a propósito (denegación de servicio sobre su cuenta); la espera progresiva frena la fuerza bruta sin ese efecto
Inactividad de sesión	15 min; funcionarios además 8 h absolutas	Equipos compartidos en familia, cibercafés y ventanillas

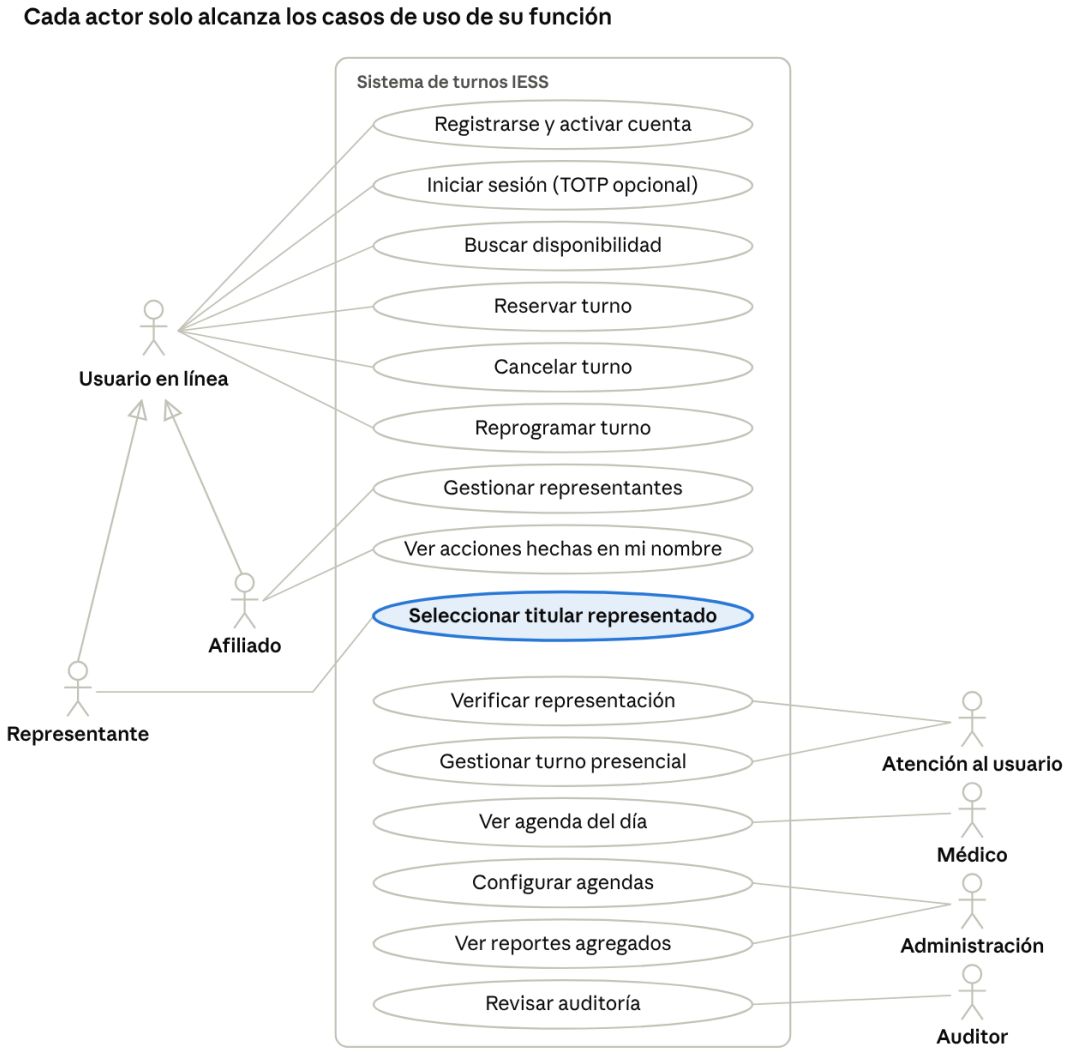
Disponibilidad y mantenimiento (RNF-02)

La solicitud del cliente (2 h diarias sin reservas) retira el servicio unas 60 h al mes, el 8 % del tiempo y eso no seria disponibilidad continua.

- **Despliegues sin corte:** con dos nodos de aplicación, se actualiza uno mientras el otro atiende. La mayoría de los cambios no necesita ventana.
- **Domingo de 01:00 a 03:00:** es la franja de menor demanda esperada, fuera de la jornada laboral de los afiliados y de la atención presencial; el mantenimiento lo realiza el equipo de TI de guardia, no el personal de ventanilla, así que el horario laboral no es una limitación.
- **Anuncio con 72 h** en la app y por correo, para que nadie planifique reservar en esa franja.
- **Validación:** el horario es un supuesto.

1.5 Diagrama de casos de uso

El alcance final tiene 15 casos de uso y ninguno toca datos clínicos y ningún funcionario alcanza todos. El representante hereda las operaciones del usuario en línea, pero solo puede ejercerlas tras seleccionar un titular que lo autorizó (caso resaltado).



casos de uso del alcance final con 7 actores, 15 casos

- **Generalización:** afiliado y representante son especializaciones de *Usuario en línea*; ambos se registran, inician sesión y operan turnos, pero el representante lo hace siempre en nombre de un titular y dentro del alcance concedido.
- **Soporte** no aparece porque no tiene casos de uso de negocio: solo consulta el estado técnico, sin datos personales (está en la fuente PlantUML).
- Las relaciones `<<include>>` y `<<extend>>` y los sistemas externos se omiten en el dibujo para mantenerlo legible; están completos en la fuente.

Código PlantUML

```
@startuml casos_de_uso_turnos
left to right direction
skinparam packageStyle rectangle

actor "Usuario en línea" as Usuario
```

```
actor "Afiliado" as Afiliado
actor "Representante" as Representante
actor "Atención al usuario" as Atencion
actor "Médico" as Medico
actor "Administración" as Admin
actor "Soporte" as Soporte
actor "Auditor" as Auditor
actor "Servicio de afiliación IESS" as SAfil <<sistema>>
actor "Agenda IESS" as SAgenda <<sistema>>
actor "Servicio de correo" as SCorreo <<sistema>>

Afiliado --|> Usuario
Representante --|> Usuario

rectangle "Sistema de turnos IESS" {
  usecase "Registrarse y activar cuenta" as UC01
  usecase "Iniciar sesión" as UC02
  usecase "Verificar segundo factor (TOTP)" as UC02a
  usecase "Buscar disponibilidad" as UC03
  usecase "Reservar turno" as UC04
  usecase "Validar afiliación" as UC04a
  usecase "Verificar límite de un turno por especialidad" as UC04b
  usecase "Cancelar turno" as UC05
  usecase "Reprogramar turno" as UC06
  usecase "Confirmar acción crítica" as UCc
  usecase "Notificar por correo" as UCn
  usecase "Gestionar representantes" as UC07
  usecase "Ver acciones hechas en mi nombre" as UC08
  usecase "Seleccionar titular representado" as UC09
  usecase "Verificar representación" as UC10
  usecase "Gestionar turno presencial" as UC11
  usecase "Ver agenda del día" as UC12
  usecase "Configurar agendas" as UC13
  usecase "Ver reportes agregados" as UC14
  usecase "Consultar estado técnico" as UC15
  usecase "Revisar auditoría" as UC16
}

Usuario -- UC01
Usuario -- UC02
Usuario -- UC03
Usuario -- UC04
Usuario -- UC05
Usuario -- UC06
Afiliado -- UC07
Afiliado -- UC08
Representante -- UC09

UC02a .> UC02 : <<extend>>\n[TOTP activado;\nsiempre en funcionarios]
UC04 .> UC04a : <<include>>
UC04 .> UC04b : <<include>>
UC04 .> UCn : <<include>>
UC05 .> UCc : <<include>>
UC05 .> UCn : <<include>>
UC06 .> UCc : <<include>>
```

```
UC06 .> UCn : <<include>>
UC07 .> UCc : <<include>>
UC09 .> UC04 : <<extend>>\n[alcance: reservar]
UC09 .> UC05 : <<extend>>\n[alcance: cancelar]
UC09 .> UC06 : <<extend>>\n[alcance: reprogramar]

Atencion -- UC10
Atencion -- UC11
Atencion -- UC02
Medico -- UC12
Medico -- UC02
Admin -- UC13
Admin -- UC14
Admin -- UC02
Soporte -- UC15
Auditor -- UC16

UC04a -- SAfil
UC03 -- SAgenda
UC04 -- SAgenda
UCn -- SCorreo
@enduml
```

1.6 Preguntas al cliente y supuestos

N.º	Pregunta al cliente	Requisito	Supuesto adoptado mientras tanto
P1	¿Con cuántos días de anticipación publica cupos la agenda del IESS?	RF-03	30 días
P2	¿Qué condición de afiliación impide reservar (mora, cesantía, tipo de seguro)?	RF-12	El servicio de afiliación responde solo "puede reservar: sí/no"
P3	¿Hay especialidades que exijan derivación previa?	RF-04	Si existen, se valida solo "tiene derivación: sí/no" con el sistema origen, sin traer datos clínicos
P4	¿Qué documentos acepta el IESS para acreditar tutela, curaduría o poder?	RF-08	Los documentos originales verificados en ventanilla
P5	¿Acepta que un adolescente de 15 a 17 años gestione sus turnos y que la representación de sus padres requiera su aceptación?	RF-07, RF-08	Sí, conforme a los arts. 21 y 24 de la LOPDP
P6	¿Los servicios de afiliación y agenda exponen una API documentada, con qué	RF-12, RS-04	API con credenciales de servicio y TLS, simulada en el

N.º	Pregunta al cliente	Requisito	Supuesto adoptado mientras tanto
	autenticación y límites?		prototipo
P7	¿Qué proveedor y dominio de correo usará el IESS?	RF-10	Dominio institucional con SPF, DKIM y DMARC; el proveedor es encargado del tratamiento con contrato (art. 34)
P8	¿El equipo de TI puede cubrir una guardia el domingo de 01:00 a 03:00?	RNF-02	Sí en caso de que no, martes de 22:00 a 24:00
P9	¿Existe infraestructura institucional (centro de datos o nube aprobada) donde desplegar?	RNF-01	Centro de datos institucional
P10	¿Qué plazos de conservación exige la normativa interna del IESS para turnos y auditoría?	RS-08	
P11	Si existe interés en analítica o IA, ¿con qué finalidad concreta y qué convenio?	RS-08	Ninguno, solo estadística agregada y anonimizada

Supuestos generales: el afiliado tiene cédula ecuatoriana; la agenda del IESS es la fuente de verdad de los cupos; la mayoría de edad es 18 años; el entregable es una propuesta y un prototipo, no un sistema en producción, por lo que los servicios del IESS y el correo se simulan.

2. Análisis de datos

El sistema trata 12 tipos de datos pero ninguno procedente de la historia clínica.

De los 18 datos personales, 13 no se recogen. Dos necesitan protección reforzada y la especialidad del turno, porque la LOPDP considera dato de salud la información sobre la prestación de atención sanitaria, y los datos de menores, que son categoría especial.

2.1 Referencia para la gestion de los datos

Norma		Disposiciones
Constitución de la República	R.O. 449, 20-oct-2008	Art. 66.19 (protección de datos), art. 32 (derecho a la salud), art. 225 (sector público)
Ley Orgánica de Protección de Datos Personales (LOPDP)	R.O. 5.º Supl. 459, 26-may-2021; reforma R.O. 5.º	Art. 4 (definiciones), 7 (bases de licitud), 10 (principios), 21 y 24 (niñas, niños y adolescentes), 25–26 y 30–31 (categorías especiales y salud), 33–

Norma		Disposiciones
	Supl. 290, 22-may-2026	34 (comunicación y encargados), 37–43 (seguridad, riesgos, evaluación de impacto, brechas), 47–48 (obligaciones y delegado)
Reglamento General a la LOPDP, D.E. 904	R.O. 3.er Supl. 435, 13-nov-2023	Desarrollo de consentimiento, delegado, notificación de brechas y evaluación de impacto
Res. SPDP-SPD-2025-0003-R	R.O. 4.º Supl. 41, 19-may-2025	Guía de gestión de riesgos y evaluación de impacto
Res. SPDP-SPD-2026-0005-R	25-feb-2026	Tratamiento a gran escala: registro de actividades de tratamiento
Ley Orgánica de Salud	R.O. Supl. 423, 22-dic-2006	Art. 7 f: confidencialidad de la información de salud del paciente
Reglamento de información confidencial en el Sistema Nacional de Salud, A.M. 5216 (MSP)	—	Documentos que contienen información de salud y su manejo confidencial
Código Orgánico Integral Penal	R.O. Supl. 180, 10-feb-2014	Art. 178 (violación a la intimidad), 229 (revelación ilegal de base de datos), 234 (acceso no consentido a un sistema informático)
EGSI 3.0, A.M. MINTEL-MINTEL-2024-0003	R.O. 3.er Supl. 509, 10-mar-2024	Mecanismo gubernamental de seguridad exigido por el art. 38 LOPDP

El IESS cita la Ley Orgánica de Salud (art. 7 f) y la LOPDP (art. 26) en sus formularios de acceso a la historia clínica (HCAM, 2025), por lo tanto se guía en base a eso tambien.

2.2 Inventario de datos

Dato	Finalidad	Clasificación	Necesidad	Base	Acceso	Conservación propuesta
Cédula	Identificar al titular y validar afiliación	Confidencial	Imprescindible	Art. 7.4	Titular, representante, atención (enmascarada)	Vida de la cuenta mas 2 años
Nombres y apellidos	Identificar en ventanilla y en agenda	Confidencial	Imprescindible	Art. 7.4	Titular, representante, atención, médico (su	Vida de la cuenta + 2 años

Dato	Finalidad	Clasificación	Necesidad	Base	Acceso	Conservación propuesta
					agenda)	
Fecha de nacimiento	Verificar identidad en el registro; calcular edad para reglas de representación	Confidencial	Necesario, nunca como secreto	Art. 7.4	Sistema y atención solo al verificar	Vida de la cuenta + 2 años
Correo verificado	Activación, notificaciones, recuperación	Confidencial	Imprescindible (RF-01)	Art. 7.4	Titular; sistema de notificaciones	Vida de la cuenta
Teléfono	Contacto alternativo	Confidencial	Opcional	Art. 7.1	Titular, atención	Hasta que el titular lo retire o cambie
Credenciales (hash de contraseña, secreto TOTP cifrado, códigos de recuperación en hash)	Autenticar	Confidencial reforzado	Imprescindible	Art. 7.4	Solo el proceso de autenticación	Vida de la cuenta
Turno(establecimiento, fecha, hora, estado, código)	Gestionar la cita	Confidencial	Imprescindible	Art. 7.4	Titular, representante, atención y médico del establecimiento	2 años desde la fecha del turno; luego anonimizado para estadística
Turno: especialidad	Asignar el cupo correcto	Confidencial reforzado (salud)	Imprescindible	Art. 7.4, art. 30	Titular, representante con alcance, atención y médico del	Igual que el turno

Dato	Finalidad	Clasificación	Necesidad	Base	Acceso	Conservación propuesta
					establecimiento pero nunca en correos ni listados generales	
Resultado de validación de afiliación (sí/no y fecha)	Permitir reservar	Interno	Necesario	Art. 7.4	Sistema	Hasta la siguiente validación
Representación (relación descriptiva, base, alcance, vigencia, verificación, revocación)	Autorizar a un tercero	Confidencial y reforzado si el titular es menor	Necesario si se usa	Art. 7.1, 8, 21 y 24	Titular, representante, atención (verificación)	Vigencia + 2 años, para atender reclamos
Documento de verificación de representación	Acreditar la representación	Confidencial reforzado	Transitorio	Art. 18.1	Solo el funcionario que verifica	Se elimina al verificar o a los 7 días (RS-07)
Registro de auditoría	Trazabilidad, no repudio, investigación de brechas	Confidencial	Imprescindible	Art. 10 k, art. 43	Solo auditor	2 años (supuesto, P10)

Criterio de los plazos: la ley no fija un plazo para turnos, así que se presupone un plazo basado en el principio de conservación (art. 10 i), no más de lo necesario y con plazo de supresión definido. Dos años cubren reclamos y el ejercicio de derechos del titular ya después, los turnos se conservan solo anonimizados para estadística, lo que la ley permite (art. 10 i, segundo inciso). Las copias de respaldo rotan cada 35 días, de modo que un dato eliminado desaparece también de ellas en ese plazo.

2.3 Datos solicitados que no se recogen

Datos (requisito)	Clasificación legal	Motivo de exclusión	Disposición

Datos (requisito)	Clasificación legal	Motivo de exclusión	Disposición
Empleador, cargo, sueldo, cuenta bancaria, contrato (I03)	Personales y financieros	Sin finalidad en un turno ademas la afiliación se valida con el servicio del IESS	LOPDP art. 10 d, e y f
Diagnósticos, antecedentes, medicamentos, alergias, laboratorio (I04)	Datos de salud, categoría especial	Corresponden a la historia clínica por lo que su tratamiento está reservado a quien presta la atención y bajo secreto profesional	LOPDP arts. 25 c, 26, 30 y 31.1; Ley Orgánica de Salud art. 7 f
Religión, afiliación política (I05)	Datos sensibles	Tratamiento prohibido salvo excepciones (art. 26) que no concurren	LOPDP arts. 4 y 26
Composición familiar (I05)	Personal	No autoriza nada. La representación se registra solo cuando se otorga	LOPDP art. 10 e
Conservación indefinida y cesión a un proveedor de IA (I14)	—	Finalidad distinta, sin plazo y comunicación a un tercero sin base	LOPDP arts. 10 d e i, 33; infracción grave art. 68.2 y 68.3; Res. SPDP-SPD-2026-0009-R

2.4 Esquema de clasificación

Nivel	Criterio	Datos	Controles mínimos
Público	Divulgarlo no causa daño	Lista de establecimientos y especialidades ofertadas, instructivos	Integridad del contenido
Interno	Uso operativo, sin identificar a un titular	Resultado de validación, métricas técnicas	Acceso autenticado
Confidencial	Identifica a un titular	Cédula, nombres, contacto, turno, representación, auditoría	Autorización por objeto, TLS, cifrado en reposo, enmascarado en pantalla, auditoría de acceso
Confidencial reforzado	Categoría especial (art. 25) o credencial	Especialidad del turno, datos de menores, credenciales, documentos de verificación	Lo anterior + exclusión de notificaciones y listados, acceso solo al personal del establecimiento y con motivo,

Nivel	Criterio	Datos	Controles mínimos
			retención mínima

Por qué la especialidad es confidencial reforzado: la LOPDP define los datos de salud como los que revelan el estado de salud, *incluida la prestación de servicios de atención sanitaria* (art. 4). Un turno en Oncología o Psiquiatría revela por sí solo información de salud, por lo que se le aplica el deber de confidencialidad del art. 30 y la confidencialidad del art. 7 f de la Ley Orgánica de Salud.

2.5 Evaluación de impacto

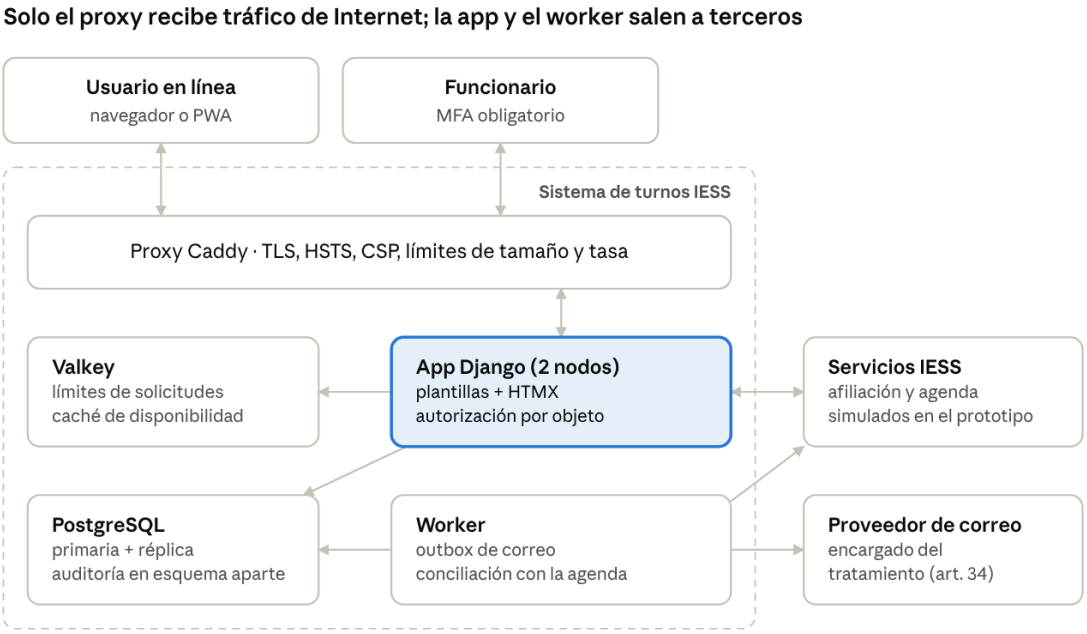
Se recomienda realizar la evaluación de impacto antes de iniciar el tratamiento. La LOPDP la hace obligatoria en el tratamiento a gran escala de categorías especiales (art. 42 b), y debe hacerse antes de empezar a tratar los datos (art. 42, último inciso). Aunque el rediseño eliminó los datos clínicos, el sistema sigue tratando, para 50.000 titulares, dos datos de categoría especial (art. 25): la especialidad del turno (salud) y los datos de menores representados.

La evaluación seguirá la guía de la Superintendencia (Res. SPDP-SPD-2025-0003-R) y se apoyará en la matriz de riesgos de la Parte 4. El tratamiento también debe inscribirse en el registro de actividades de tratamiento (art. 51; Res. SPDP-SPD-2026-0005-R) y contar con el delegado de protección de datos del IESS (art. 48.1).

3. Diseño general

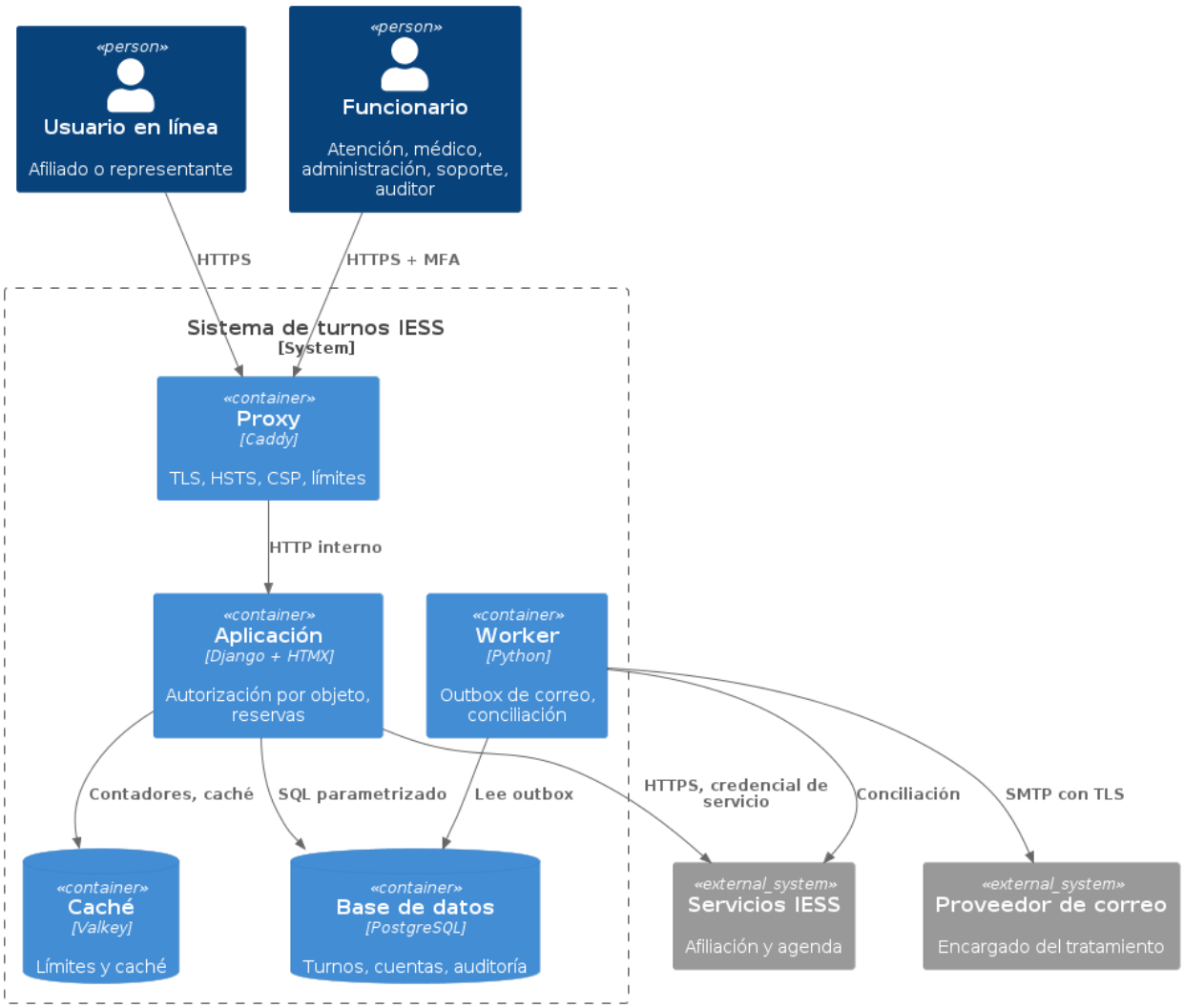
El diseño usa se basa en cinco contenedores, un único punto de entrada desde Internet y la base de datos como única fuente de verdad. Para 3.000 usuarios simultáneos bastan dos nodos de aplicación y una base de datos con réplica y los supuestos de carga se validan con las medicione.

3.1 Componentes principales



Componente	Responsabilidad	Riesgo que mitiga
Proxy (Caddy)	Única entrada desde Internet que termina TLS y añade HSTS, ademas la política de seguridad de contenido (CSP) limita tamaño y tasa de solicitudes	Captura de tráfico, intermediario y saturación también reduce lo expuesto a un solo servicio
App Django (2 nodos)	Páginas y formularios, autenticación, sesiones y CSRF, tambien permite la autorización por rol y por objeto en cada solicitud, reserva en transacción y llamada síncrona a afiliación y agenda con su tiempo de espera	Acceso a datos ajenos (IDOR), escalada de privilegios, doble reserva y el segundo nodo evita el punto único de fallo
Worker	Envía los correos de la tabla de salida (*outbox*) y concilia turnos con la agenda	Notificaciones perdidas o enviadas por reservas que no se completaron
PostgreSQL (primaria + réplica)	Cuentas, turnos, representaciones y salida de notificaciones así como auditoría en un esquema aparte, solo anexado, con rol de escritura distinto al de la app	Integridad, pérdida de datos, borrado de evidencias
Valkey	Contadores de límites de solicitudes y caché de disponibilidad, lo importantes es que **no guarda sesiones ni datos de turnos**. Si falla, los límites de	Fuerza bruta y saturación, sin que su caída abra la puerta a

Componente	Responsabilidad	Riesgo que mitiga
	inicio de sesión pasan a una tabla de PostgreSQL	ellas



3.2 Tecnologías, versiones y vulnerabilidades conocidas

Componente	Versión fijada	Soporte	Vulnerabilidad de referencia	¿Afecta?	Decisión que deriva
Python	3.13	Seguridad hasta oct-2029 (python.org)			Compatible con Django 5.2, 3.15 (oct-2026) es demasiado reciente para el

Componente	Versión fijada	Soporte	Vulnerabilidad de referencia	¿Afecta?	Decisión que deriva
					ecosistema
Django	**5.2 LTS** (5.2.17)	Seguridad hasta abr-2028 (djangoproject.com)	CVE-2026-1312, inyección SQL en `order_by()` con `FilteredRelation`; CVSS 3.1 **5.4** (AV:N/AC:L/PR:L/UI:N/C:L/I:L/A:N)	No por que fue corregida en 5.2.11	Aportar CSRF, escape contra XSS, ORM parametrizado, sesiones, Argon2 y permisos reduce el código de seguridad propio. Se elige 5.2 LTS sobre 6.1 por su ventana de soporte más larga; la CSP se aplica desde el proxy
PostgreSQL	**18** (18.6)	Hasta nov-2030	CVE-2025-1094, inyección SQL en las funciones de escape de libpq; CVSS 3.1 **8.1** (AV:N/AC:H/PR:N/UI:N/C:H/I:H/A:H) (NVD)	No, esto afecta a versiones anteriores a 17.3 y 16.7 y además el ORM usa parámetros, no esas funciones	Transacciones, bloqueo de filas y restricciones únicas resuelven la doble reserva; se descarta la 19 por recién publicada
Valkey	**9.0.5** o posterior	Línea con parches de jul-2026 (releases)	CVE-2025-67733, inyección en el protocolo vía errores de scripts Lua; CVSS 3.1 **8.5** según GitHub (S:C) y **7.1** según otra fuente (S:U)	No, corregida en 9.0.2	Licencia BSD. No se expone a Internet, exige contraseña y se bloquean los comandos de scripting por ACL, lo que elimina el vector aunque surja otro fallo similar
Caddy	**2.11.4** o posterior	Sin LTS; versión	En 2026 se publicaron	No en 2.11.4, y los módulos	Las decisiones de autorización están

Componente	Versión fijada	Soporte	Vulnerabilidad de referencia	¿Afecta?	Decisión que deriva
		vigente jun-2026	varias, entre ellas CVE-2026-27587 (evasión de autorización por ruta, CVSS **9.1**) y CVE-2026-27586 (mTLS que falla abierto, **8.2**)	afectados (FastCGI, `forward_auth`, autorización por ruta) no se usan	en Django. Se deshabilita la API de administración (CVE-2026-27589). La frecuencia de avisos obliga a vigilar sus publicaciones y por su lado Nginx queda como alternativa si el IESS lo estandariza
HTMX	2.x, servido desde el propio servidor				Menos JavaScript y sin lógica de autorización en el cliente ademas sin CDN externo (cadena de suministro)
TOTP	django-otp		Se verificará al fijar dependencias		Secreto cifrado en reposo, códigos de recuperación en hash, límite de intentos
Contenedores	Docker Compose				Separa proxy, app, worker, base de datos y caché con redes internas; reproducible para la evaluación

¿Por qué la puntuación CVSS no basta?

Dos fuentes dan 8.5 y 7.1 al mismo fallo de Valkey porque difieren en si el impacto cruza a otros componentes (alcance). Por eso, en la la puntuación base se ajusta a nuestro entorno antes de convertirla en probabilidad.

3.3 Roles y permisos

Rol	Alcance	Puede	No puede	Autenticación
Afiliado	Sus propios datos	Buscar, reservar, cancelar, reprogramar; gestionar representantes; ver historial	Ver datos de otros	Contraseña; TOTP recomendado
Representante	Titulares que lo autorizaron, dentro del alcance concedido	Lo concedido (ver, reservar, cancelar, reprogramar)	Cambiar datos de contacto del titular y delegar a un tercero	Contraseña; TOTP recomendado
Atención al usuario	Su establecimiento	Gestionar turnos presenciales; verificar representaciones	Exportar listados y ver datos de otros establecimientos	TOTP obligatorio; sesión 8 h máx.
Médico	Su agenda	Ver la agenda del día (nombre, hora, estado)	Ver contacto del afiliado y modificar turnos	TOTP obligatorio
Administración	Configuración	Configurar agendas; ver reportes agregados; dar de alta funcionarios	Ver datos personales individuales y asignarse roles a sí mismo	TOTP obligatorio
Soporte	Plataforma	Ver estado técnico y registros sin datos personales (ID de correlación)	Ver o modificar turnos y datos personales	TOTP obligatorio
Auditor	Auditoría	Leer la auditoría	Modificar datos o auditoría	TOTP obligatorio

3.4 Integraciones, notificaciones y recorrido de los datos

La reserva es el punto importante ya que cruza las tres fronteras expuestas antes, depende de dos servicios externos y genera una notificación. Se confirma solo cuando los tres pasos tienen éxito. El turno, la notificación pendiente y el evento de auditoría se escriben en una sola transacción, así que o se

guardan los tres o ninguno.

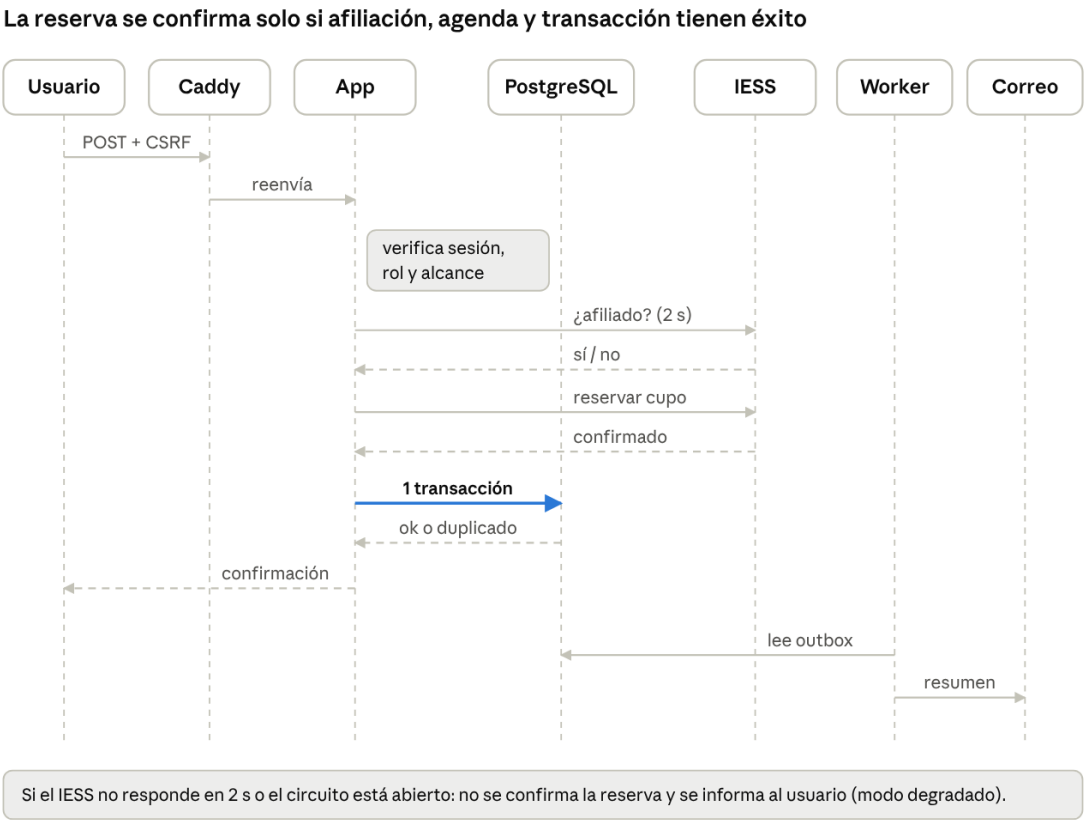
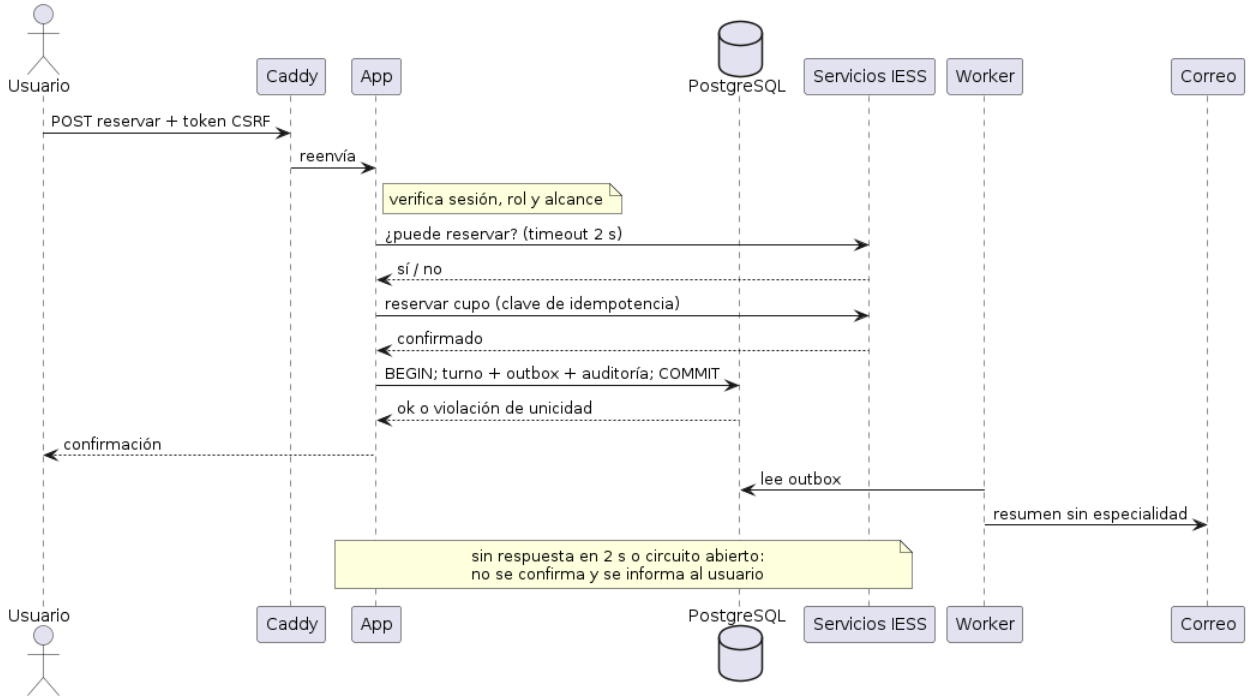


Diagrama de secuencia

Integración	Datos que salen / vuelven	Controles	Si falla
Afiliación IESS	Cédula / "si puede reservar o no"	Credencial de servicio rotada, TLS, validación de esquema de la respuesta, tiempo de espera de 2 s, corte automático tras fallos repetidos	se muestra disponibilidad, no se confirma la reserva
Agenda IESS	Cupo y cédula / confirmación	Lo anterior ademas de la clave de idempotencia por reserva, para que un reintento no cree dos citas	el worker ve los turnos que queden pendientes
Proveedor de correo	Correo, fecha, hora, establecimiento y código de turno	SMTP con TLS, SPF/DKIM/DMARC, contrato de encargado (LOPDP, art. 34); límite de envíos por cuenta y	La notificación queda en la tabla de salida y se reintenta ademas el estado del

Integración	Datos que salen / vuelven	Controles	Si falla
	(sin especialidad)	día	turno siempre se ve en la app



3.5 Interfaz y seguridad visual

La interfaz es web responsiva con manifiesto PWA instalable, sin datos guardados en el dispositivo; su diseño minimalista también es un control, porque lo que no se muestra no puede filtrarse por una captura o una pantalla ajena.

Criterio	Justificación
Fondo neutro, tipografía legible, jerarquía por espaciado, pocos contenedores sin bordes marcados	Menos errores de usuario (amenaza humana accidental); público amplio que incluye adultos mayores
Formularios cortos	Solo se piden los datos de la Parte 2 (minimización, art. 10 e)
Listados sin datos sensibles; cédula enmascarada (17•••••89)	Confidencialidad ante observación y capturas; la especialidad solo aparece en el detalle del turno

Criterio	Justificación
Estados con color y texto	Accesibilidad: el estado no depende solo del color
Acciones destructivas diferenciadas y con confirmación que resume titular, especialidad, fecha y hora	Evita cancelaciones por error (integridad)
Mensajes uniformes: "usuario o contraseña incorrectos"; misma respuesta para "no existe" y "no autorizado"	Impide enumerar cédulas o confirmar que una persona es afiliada
Banda fija "Actuando en nombre de: [titular]"	Evita operar sobre la persona equivocada
Aviso antes del cierre por inactividad	Equipos compartidos
Sin datos en almacenamiento local, IndexedDB ni caché del *service worker*	Un teléfono perdido no expone turnos; la disponibilidad siempre se consulta al servidor

Toda validación y autorización se repite en el servidor: la interfaz reduce errores y exposición, pero no es la frontera de seguridad.

3.6 Capacidad y disponibilidad

Usuarios simultáneos y operaciones

$$\lambda = \frac{U}{Z} = \frac{3000 \text{ usuarios}}{10 \text{ s}} = 300 \text{ solicitudes/s}$$

$$C = \frac{\lambda \cdot S}{\rho} = \frac{300 \cdot 0{,}05}{0{,}7} \approx 22 \text{ solicitudes concurrentes}$$

- **Aplicación:** 2 nodos de 4 vCPU con 9 procesos × 2 hilos (regla de Gunicorn: 2 × núcleos + 1) = 36 solicitudes concurrentes, unas 500 solicitudes/s. Si cae un nodo quedan 18, unas 250 solicitudes/s (84 % del pico); los límites de tasa protegen el resto.
- **Escrituras:** si el 10 % son reservas o cancelaciones, son 30 transacciones/s, una carga baja para PostgreSQL. El riesgo real es la contención sobre un mismo cupo: se bloquea la fila del cupo y la segunda solicitud recibe "cupo ya tomado" de inmediato.
- **Conexiones:** 36 de la app + 4 del worker + administración ≈ 45, dentro del límite por defecto de PostgreSQL (100); no hace falta un agrupador de conexiones.

Almacenamiento (2 años, conservación de la Parte 2)

Dato	Cálculo	Volumen
Cuentas	50.000 × 2 KB	0,1 GB

Dato	Cálculo	Volumen
Turnos	6 turnos por afiliado al año (supuesto) × 50.000 × 1 KB × 2 años	0,6 GB
Auditoría	20 eventos por afiliado al mes (supuesto) × 50.000 × 12 × 0,5 KB × 2 años	12 GB
Total con índices (×2)		**≈ 26 GB** → se provisionan 100 GB SSD por nodo de BD
Copias de respaldo	Copia diaria comprimida (≈ 4 GB) × 35 días + registro de transacciones	≈ 250 GB en almacenamiento separado

Disponibilidad

Infraestructura propuesta

Función	Nodos	Recursos por nodo	Por qué
Proxy	2, con IP virtual o balanceador institucional	2 vCPU, 2 GB	Evita que el punto de entrada sea un fallo único
Aplicación + worker	2	4 vCPU, 8 GB	Cálculo anterior; despliegue sin corte nodo por nodo
PostgreSQL	2 (primaria + réplica)	4 vCPU, 16 GB, 100 GB SSD	RPO 5 min, RTO 1 h
Valkey	1	2 vCPU, 2 GB	si cae, los límites de login pasan a PostgreSQL
Copias de respaldo	Almacenamiento separado	250 GB	Recuperación ante ransomware o borrado (art. 37.2)

Infraestructura aceptable comparado con el PC de 8 GB de I12.

Mediciones para validar el dimensionamiento

Medición	Cómo	Que valida
Tiempo de servicio por vista (*S*)	Prueba de carga con Locust	p95 de búsqueda < 500 ms y de reserva < 1 s
Tiempo entre solicitudes (*Z*) y	Registros de acceso de un piloto e	λ de diseño y ventana de

Medición	Cómo	Que valida
pico real	histograma por hora y día durante 4 semanas	mantenimiento (1.4)
Carga con 3.000 usuarios virtuales, con ambos nodos y con uno caído	Locust	Errores < 1 % y degradación controlada
Contención en un cupo	100 solicitudes simultáneas al mismo cupo	Exactamente 1 reserva confirmada
Consultas lentas y conexiones	`pg_stat_statements`, monitoreo de conexiones	Que la BD no sea el cuello de botella
Crecimiento de almacenamiento	Tamaño de tablas y auditoría por mes	Supuestos de 6 turnos y 20 eventos por afiliado
Latencia y disponibilidad de los servicios IESS	Métricas del cliente de integración	Tiempo de espera de 2 s y umbral de corte
RPO y RTO	Simulacro de restauración y de promoción de la réplica	5 min y 1 h
Memoria y aciertos de caché de Valkey	Estadísticas del propio servicio	Tamaño de 2 GB

4. Matriz de riesgos

Se identificaron 22 riesgos: 10 críticos, 7 altos y 5 medios. Si tenemos en cuenta los controles propuestos, ninguno queda por encima de medio (9 medios y 13 bajos). En casi todos los casos, los controles reducen la probabilidad.

4.1 Valoración

La LOPDP exige una metodología que considere las particularidades del tratamiento, las de las partes involucradas, y las categorías y el volumen de datos (art. 40), y que las medidas se generen de ese análisis (art. 41). Se sigue la guía de gestión de riesgos de la Superintendencia (Res. SPDP-SPD-2025-0003-R). La escala de impacto incorpora los tres factores del art. 40: tipo de tratamiento web, partes vulnerables (menores, adultos mayores) y 50.000 titulares con un dato de salud indirecto.

Probabilidad (P)

Valor	Nivel	Criterio	Equivalencia CVSS ambiental (4.2)

Valor	Nivel	Criterio	Equivalencia CVSS ambiental (4.2)
1	Muy improbable	Requiere acceso privilegiado y evadir varios controles o la versión no está afectada y hay política de parcheo	No afectada
2	Improbable	Requiere habilidad alta o condiciones poco comunes	0,1–3,9 (baja)
3	Posible	Técnica conocida con una condición previa (cuenta válida, acceso interno, patrón de código concreto)	4,0–6,9 (media)
4	Probable	Técnica pública y de poca habilidad sobre un sistema expuesto a Internet categoría líder en OWASP o algún vector frecuente en el DBIR 2026	7,0–8,9 (alta)
5	Casi seguro	Ocurrirá si no se tiene un control, el requisito original lo produce por diseño o hay explotación activa	9,0–10,0 (crítica)

Impacto (I)

Se toma la dimensión más alta.

Valor	Nivel	Datos y titulares	Servicio	Consecuencia legal
1	Mínimo	Sin datos personales	Sin interrupción perceptible	Ninguna
2	Bajo	Datos de un titular, sin categoría especial	Menos de 1 h fuera del pico	Ninguna
3	Medio	Datos personales de varios titulares	Horas o pérdida de cupos	Posible reclamo del titular (art. 62)
4	Alto	Muchos titulares, o categoría especial de un grupo	Interrupción en horas pico	Notificación a SPDP, ARCOTEL y CSIRT en 5 días (art. 43) y a titulares (art. 46)
5	Crítico	Datos de salud o de menores a gran escala; pérdida irrecuperable	Caída prolongada	Infracción grave (art. 68) y medidas correctivas (art. 65)

Nivel, prioridad y aceptación

$$\text{Nivel} = \text{P} \times I \quad (1 \text{ a } 25)$$

Nivel	Rango	Prioridad	Tratamiento
Crítico	15–25	1	Tratar en el diseño y/o bloquea la entrega
Alto	10–14	2	Tratar antes de producción
Medio	5–9	3	Tratar en el plan y/o aceptable como residual con monitoreo
Bajo	1–4	4	Aceptar y monitorear

4.2 Cálculo CVSS de vulnerabilidades conocidas

CVSS mide la **severidad** de una vulnerabilidad, no el riesgo. La propia especificación pide no usarlo solo para evaluar riesgo y complementar la puntuación base con las métricas temporales y ambientales del entorno (FIRST, CVSS v3.1 User Guide). Aquí se recalcula cada puntuación para nuestro entorno y se convierte en P con la tabla anterior.

Se usa **CVSS v3.1**: es la versión en que NVD y los emisores publicaron los vectores de estos CVE, y mezclar versiones haría incomparables las cifras.

Pesos usados: AV N 0,85 · A 0,62 · AC L 0,77 · H 0,44 · PR L 0,62 (0,68 con S:C) · H 0,27 (0,50 con S:C) · UI N 0,85 · C/I/A H 0,56 · L 0,22 · N 0 · CR/IR/AR H 1,5 · M 1 · L 0,5 · E U 0,91 · P 0,94 · RL O 0,95 · RC C 1.

	CVE-2026-1312 (Django)	CVE-2025-67733 (Valkey)	CVE-2025-1094 (PostgreSQL)
Fallo	Inyección SQL en `order_by()` con `FilteredRelation`	Inyección en el protocolo vía errores de Lua	Inyección SQL en funciones de escape de libpq
Vector base publicado	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:L/A:H	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Recálculo base	ISS 0,392 · Impacto 2,51 · Explot. 2,84 → **5,4**	ISS 0,657 · Impacto 4,72 · Explot. 3,11 → 1,08 × 7,83 → **8,5**	ISS 0,915 · Impacto 5,87 · Explot. 2,22 → **8,1**
Coincide con	NVD 5,4	GitHub (emisor) 8,5; otra fuente da 7,1 con S:U	NVD 8,1
Ajuste ambiental y por qué	MAC:H (solo explotable si el código expande diccionarios del usuario en `FilteredRelation`, patrón que no usamos); CR:H, IR:H (turnos y especialidad); E:U (sin explotación conocida según CISA); RL:O; RC:C	MAV:A (sin exposición a Internet, solo red de la app); MPR:H (requiere la contraseña de Valkey que solo tiene la app); AR:L (no crítico: hay respaldo en PostgreSQL); E:P (PoC pública); RL:O; RC:C	No se calcula: PostgreSQL 18 no está en el rango afectado (anteriores a 17.3, 16.7…)

	CVE-2026-1312 (Django)	CVE-2025-67733 (Valkey)	CVE-2025-1094 (PostgreSQL)
Cálculo ambiental	MISS 0,551 · MImpacto 3,54 · MExplot. 1,62 → 5,2 × 0,91 × 0,95 → **4,5**	MISS 0,438 · MImpacto 3,08 · MExplot. 1,67 → 1,08 × 4,75 → 5,2 × 0,94 × 0,95 → **4,7**	—
Severidad ambiental	Media	Media	No aplica
P si la versión estuviera afectada	3	3	—
P con la versión elegida	1 (corregido en 5.2.11; usamos 5.2.17)	1 (corregido en 9.0.2; usamos 9.0.5) y el scripting se bloquea por ACL	1
Uso en la matriz	R13	R14	Evidencia de R13

Fuentes de los vectores: CVE-2026-1312 (CIRCL/NVD), CVE-2025-67733 (CERT.hr), CVE-2025-1094 (NVD).

Lectura: el ajuste ambiental baja la severidad de Valkey de alta (8,5) a media (4,7), porque en nuestro diseño no está expuesto a Internet y exige credencial. La discrepancia 8,5/7,1 entre fuentes no cambia la conclusión, y el factor decisivo es la versión: mantenerla corregida lleva P a 1. Por eso el riesgo real está en **dejar de parchear**, y así se modela en R13–R15.

4.3 Identificación de riesgos

La matriz se divide en tres tablas.

ID / requisito	Activo o dato	Amenaza/atacante	Vulnerabilidad o condición	Escenario y consecuencia	Propiedad
R01 / RS-02, RF-03 a RF-06	Turnos y especialidad	Afiliado autenticado malintencionado o curioso	La vista no verifica que el turno pertenezca al usuario (IDOR)	Cambia el identificador en la URL y ve o cancela turnos ajenos puede generar divulgación de datos de salud de muchos titulares	C, I
R02 / RS-01	Cuentas de afiliados	Ciberdelincuente con listas de credenciales	Reutilización de contraseñas, sin segundo	Relleno de credenciales automatizado puede causar toma	C, I, Au

ID / requisito	Activo o dato	Amenaza/atacante	Vulnerabilidad o condición	Escenario y consecuencia	Propiedad
		filtradas	factor ni límite de intentos	de cuentas, reservas y cancelaciones en su nombre	
R03 / RS-01, RS-02	Cuentas de funcionarios	Atacante externo con phishing	Sin MFA (I07 original)	Roba la contraseña de un funcionario de atención y consulta datos de afiliados	C, Au
R04 / RS-02, RS-05	Datos de afiliados	Funcionario con acceso legítimo (insider)	Todos los roles ven todos los expedientes (I08)	Consulta turnos de conocidos o personas públicas puede causar divulgación	C
R05 / RF-04, RS-06	Cupos de atención	Tramitadores con bots	Sin límite de turnos por persona ni de solicitudes	Acaparan cupos para revenderlos puede causar afiliados sin turno	D, I
R06 / RF-07 a RF-09, RS-07	Turnos del titular, especialidad	Familiar o expareja que conoce cédula y fecha de nacimiento	Representación con solo esos dos datos (I06)	Cancela turnos de un adulto mayor o ve su especialidad puede causar daño a su atención	C, I, Au
R07 / RF-04, RF-06	Integridad de la agenda	Concurrencia en la apertura de agendas (no maliciosa)	Disponibilidad comprobada en código sin bloqueo ni restricción en la BD	Dos usuarios reciben el mismo cupo puede causar atención duplicada o rechazada en ventanilla	I, D
R08 / RF-10	Especialidad y diagnóstico	Tercero que ve el correo o SMS; proveedor de mensajería	Notificación con especialidad, diagnóstico y enlace sin sesión (I09)	El mensaje se lee en una pantalla bloqueada o se reenvía; el enlace abre datos puede causar divulgación de salud	C
R09 / RF-	Confianza del	Atacante	Correos sin	Phishing con el	Au, C

ID / requisito	Activo o dato	Amenaza/atacante	Vulnerabilidad o condición	Escenario y consecuencia	Propiedad
10	afiliado	externo que imita al IESS	autenticación de dominio; hábito de pulsar enlaces	formato del IESS puede causar robo de credenciales	
R10 / RS-05	Contraseñas, tokens	Persona de soporte o atacante con acceso a los registros	Registro de contraseñas, tokens y solicitudes completas (I11)	Quien lee el registro puede suplantar a cualquier usuario	C, Au, Po
R11 / RS-05	Auditoría	Atacante con acceso o insider que quiere ocultar su rastro	Registros en la misma BD y con los permisos de la app	Borra o altera eventos puede causar no se puede reconstruir la brecha en 5 días (art. 43)	I, no repudio
R12 / RS-02, RS-03	Base de datos	Atacante externo	Consultas concatenadas o salida sin escapar	Inyección SQL o XSS puede causar extracción o alteración de datos	C, I
R13 / RS-04, 3.2	Aplicación (Django y dependencias)	Atacante que explota un CVE publicado	Dependencia sin parchear (p. ej., CVE-2026-1312)	Inyección SQL a través del framework puede causar acceso a datos	C, I
R14 / 3.2	Valkey	Atacante que ya está en la red interna	Versión sin parchear (CVE-2025-67733) o sin contraseña	Corrompe respuestas o tumba la caché puede causar límites de intentos inoperantes	I, D
R15 / 3.1, 3.2	Configuración del despliegue	Atacante externo	Modo depuración, API de administración de Caddy activa, puertos de BD	Ve trazas internas o reconfigura el proxy puede causar acceso a datos o interrupción	C, I, D

ID / requisito	Activo o dato	Amenaza/atacante	Vulnerabilidad o condición	Escenario y consecuencia	Propiedad
			expuestos		
R16 / RF-12, RS-04	Servicio de reservas	Caída o lentitud de los servicios del IESS (externa)	Llamada síncrona sin tiempo de espera	Los procesos quedan bloqueados puede causar que el sistema completo caiga	D
R17 / RS-04	Resultado de afiliación	Intermediario o servicio externo comprometido	Integración sin TLS verificado ni validación de respuesta	Respuestas falsas puede causar reservas indebidas o rechazos	I, Au
R18 / RNF-01, RNF-02	Disponibilidad del servicio	Bots o pico legítimo de 3.000 usuarios	Un solo PC de 8 GB y sin límites de tasa (I12)	Saturación en la apertura de agendas puede causar servicio caído en el pico	D
R19 / RNF-01	Datos de turnos y cuentas	Fallo de disco, corte eléctrico o ransomware	Equipo único sin copias de respaldo	Pérdida o cifrado de datos puede causar turnos irrecuperables	D, I, U, Po
R20 / RS-06	Condición de afiliado	Atacante externo	Mensajes distintos para "no existe" y "contraseña incorrecta"	Enumera cédulas y confirma quién es afiliado puede ser un insumo para fraude	C
R21 / RS-08	Todos los datos	El propio responsable y un proveedor externo	Conservación indefinida y cesión para entrenar IA (I14)	Datos usados para otra finalidad y fuera del control del IESS puede causar infracción grave	C, Po
R22 / RS-01	Sesiones	Tercero con acceso al equipo o script inyectado	Sesiones largas, cookies sin `HttpOnly` ni `Secure`	Usa una sesión abierta en un equipo compartido puede causar que alguien actúe como el titular	C, I, Au

4.4 Riesgos

El control de acceso roto sigue en el primer puesto de OWASP Top 10:2025 y apareció en el 100 % de las aplicaciones evaluadas (OWASP A01:2025), luego la configuración insegura y las fallas de la cadena de suministro ocupan los puestos 2 y 3 (OWASP, 2025). En el DBIR 2026 de Verizon, la explotación de vulnerabilidades fue el 31 % del acceso inicial, el phishing el 16 % y el abuso de credenciales el 13 %, aunque este último aparece en el 39 % de las brechas (Help Net Security; SC World).

ID	P	Justificación de P	I	Justificación de I	Nivel	Prioridad
R01	4	Cambiar un número) en OWASP A01 es la categoría más frecuente	5	Datos de salud de muchos titulares seria una infracción grave (art. 68)	20 Crítico	1
R02	4	El abuso de credenciales aparece en el 39 % de las brechas (DBIR 2026)	4	Automatizable hacia muchas cuentas, podria provocar una notificación del art. 43	16 Crítico	1
R03	4	El phishing es el 16 % del acceso inicial (DBIR 2026) y sin MFA con una contraseña es suficiente para entrar	4	Un funcionario ve datos de muchos afiliados	16 Crítico	1
R04	3	Requiere un funcionario con intención	4	Datos de un grupo	12 Alto	2
R05	4	Hay incentivo económico y es automatizable sin límites	3	Pérdida de cupos para muchos.	12 Alto	2
R06	3	Requiere conocer dos datos que circulan en fotocopias y redes	4	Afecta a vulnerables (adultos mayores) ademas de ser una especialidad expuesta	12 Alto	2
R07	4	Con 3.000 concurrentes en la apertura se esperan problemas	3	Turnos duplicados y reprocesos en ventanilla	12 Alto	2
R08	4	El requisito I09 lo produce por	4	Dato de salud de	16 Crítico	1

ID	P	Justificación de P	I	Justificación de I	Nivel	Prioridad
		diseño en cada envío; el riesgo depende de quién vea el mensaje		muchos titulares (art. 4, art. 30)		
R09	4	El phishing es el 16 % del acceso inicial (DBIR 2026)y hacia el IESS es mas probable	3	Cuentas individuales comprometidas	12 Alto	2
R10	4	El requisito I11 escribe secretos en cada solicitud	4	Permite suplantar a cualquier usuario registrado	16 Crítico	1
R11	2	Requiere acceso previo a la BD	4	Impide cumplir el art. 43 y destruye el no repudio	8 Medio	3
R12	3	La inyección sigue en OWASP con un ORM es menos frecuente, pero un fragmento de SQL crudo basta	5	Extracción masiva de la base de datos	15 Crítico	1
R13	3	CVSS ambiental de CVE-2026-1312 = 4,5 (sección 4.2), si no se parchea	4	Acceso a datos de turnos	12 Alto	2
R14	3	CVSS ambiental de CVE-2025-67733 = 4,7 (sección 4.2), si no se parchea	3	Afecta límites y caché, no datos personales	9 Medio	3
R15	4	Configuración insegura: OWASP A02:2025, presente en el 100 % de las aplicaciones evaluadas ademas según registros Caddy tuvo en 2026 un fallo en su API de administración (CVE-2026-27589)	4	Exposición de datos o del proxy	16 Crítico	1
R16	3	Las caídas de terceros ocurren sin datos del IESS se supone ocasional	4	Sin reservas en horas pico	12 Alto	2
R17	2	Requiere comprometer la red	4	Decisiones de	8 Medio	3

ID	P	Justificación de P	I	Justificación de I	Nivel	Prioridad
		o el servicio del IESS		reserva sobre datos falsos		
R18	4	Pico de 3.000 usuarios previsto por el cliente sobre un PC de 8 GB	4	Caída en el pico de demanda	16 Crítico	1
R19	3	Un disco único falla tarde o temprano así el ransomware aprovecha la explotación de vulnerabilidades (31 % del acceso inicial, DBIR 2026)	5	Pérdida irrecuperable sin copias	15 Crítico	1
R20	4	Técnica trivial y automatizable	2	Revela solo la condición de afiliado	8 Medio	3
R21	5	El requisito I14 lo exige: ocurriría por diseño	5	Datos de 50.000 titulares cedidos sin base legal, saiendo esto una infracción grave (art. 68.2 y 68.3)	25 Crítico	1
R22	3	Equipos compartidos frecuentes	3	Una cuenta a la vez	9 Medio	3

4.5 Controles, verificación y riesgo residual

Tipo de control: **Pr** preventivo, **De** detectivo, **Co** correctivo.

ID	Controles propuestos	Verificación	Residual	Justificación del residual
R01	Preventivo: verificación por objeto en cada vista, denegación por defecto, 404 uniforme, identificadores UUID Detectivo: auditoría de accesos denegados y alerta por ráfagas	Prueba automática: el usuario A pide, edita y cancela recursos de B en cada endpoint → 404	1 × 5 = 5 Medio	P baja a 1 porque cada endpoint tiene prueba de autorización; I no cambia porque si fallara, el dato expuesto sigue siendo de salud
R02	Preventivo: lista de contraseñas filtradas, 12 caracteres, Argon2id, espera progresiva por	Script con 20 intentos fallidos → espera progresiva y contraseña de la	2 × 4 = 8 Medio	La automatización queda frenada y TOTP exige un segundo factor; P no llega a 1

ID	Controles propuestos	Verificación	Residual	Justificación del residual
	cuenta e IP, TOTP Detectivo: aviso de nuevo inicio de sesión Correctivo: cierre de todas las sesiones	lista → rechazada		porque el TOTP puede capturarse con phishing
R03	Preventivo: TOTP obligatorio, alcance por establecimiento, sesión de 8 h · Detectivo: alerta por volumen de consultas inusual	Inicio de sesión de funcionario sin TOTP → rechazado; consulta fuera de su establecimiento → 404	2 × 3 = 6 Medio	P baja por el segundo factor; I baja a 3 porque el alcance limita el daño a un solo establecimiento
R04	Preventivo: rol + alcance, motivo obligatorio para consultar a un afiliado · Detectivo: auditoría de cada consulta y revisión mensual · Correctivo: retiro de permisos	Consulta sin motivo → bloqueada; el evento aparece en la auditoría con actor y motivo	2 × 3 = 6 Medio	El insider sigue teniendo acceso legítimo, pero limitado y trazable; I baja por el alcance
R05	Preventivo: un turno activo por especialidad (restricción única en BD), límites de tasa, tope de representados · Detectivo: alerta por patrones de reserva	Segunda reserva en la misma especialidad → rechazada por la BD; ráfaga → 429	2 × 2 = 4 Bajo	Un bot no puede acumular turnos; I baja porque cada cuenta tiene como máximo un cupo por especialidad
R06	Preventivo: consentimiento desde la cuenta del titular o verificación presencial, caducidad, revocación · Detectivo: correo al titular por cada acción del representante	Alta de representante con solo cédula y fecha → imposible; acción del representante → correo al titular	1 × 3 = 3 Bajo	Ya no basta con conocer dos datos; el titular se entera y revoca, lo que limita el daño
R07	Preventivo: bloqueo de la fila del cupo en la transacción, restricción única de cupo activo, clave de idempotencia	100 reservas simultáneas al mismo cupo → exactamente 1 confirmada	1 × 3 = 3 Bajo	La BD garantiza la unicidad aunque el código falle
R08	Preventivo: correo sin	Revisar plantillas:	1 × 2 = 2	El mensaje ya no

ID	Controles propuestos	Verificación	Residual	Justificación del residual
	especialidad ni diagnóstico, enlace solo al inicio de sesión, contrato de encargado (art. 34)	ningún campo de salud; el enlace no da acceso sin sesión	Bajo	contiene datos de salud; si se filtra, revela solo fecha y establecimiento
R09	Preventivo: SPF, DKIM y DMARC; formato y remitente constantes; aviso de que el IESS no pide contraseñas; TOTP · Detectivo: canal para reportar correos falsos	Herramienta de verificación de DNS muestra SPF/DKIM/DMARC válidos	3 × 2 = 6 Medio	El phishing no se elimina desde el sistema, pero el TOTP limita su efecto sobre la cuenta
R10	Preventivo: lista blanca de campos registrables, filtro de secretos, cédula enmascarada	Prueba que busca patrones de contraseña y token en los registros → sin coincidencias	1 × 3 = 3 Bajo	El registro ya no contiene secretos, pero queda información personal limitada
R11	Preventivo: esquema de auditoría separado, solo anexado, rol de escritura distinto · Detectivo: verificación periódica de la cadena de hash · Co: copia externa	Intentar borrar un evento con el rol de la app → denegado; alterar uno → la cadena de hash falla	1 × 4 = 4 Bajo	Borrar requiere comprometer dos roles y la copia externa ademas I se mantiene por el art. 43
R12	Preventivo: ORM parametrizado, prohibición de SQL crudo, escape automático de plantillas, CSP · Detectivo: análisis dinámico con OWASP ZAP	ZAP sin hallazgos de inyección; cargas SQL y XSS en cada campo → sin efecto	1 × 5 = 5 Medio	Las defensas por defecto del framework cubren la técnica; I se mantiene porque una inyección exitosa expondría toda la base
R13	Preventivo: versiones fijadas, `pip-audit` en cada construcción, parches críticos y altos en 7 días Detectivo: suscripción a avisos de seguridad de Django	`pip-audit` sin vulnerabilidades conocidas; versión 5.2.17 ≥ 5.2.11	1 × 4 = 4 Bajo	Con la versión corregida y la política de parcheo, P = 1 según 4.2
R14	Preventivo: Valkey 9.0.5+, contraseña, red interna,	Desde la red de la app, `EVAL` →	1 × 3 = 3	Sin scripting desaparece la

ID	Controles propuestos	Verificación	Residual	Justificación del residual
	comandos de scripting bloqueados por ACL; respaldo de límites en PostgreSQL	denegado por ACL; sin contraseña → rechazado	Bajo	precondición del CVE; si Valkey cae, los límites siguen en PostgreSQL
R15	Preventivo: lista de verificación de despliegue (DEBUG apagado, API de Caddy deshabilitada, solo puertos 80/443 expuestos, cabeceras de seguridad) Detectivo: escaneo de puertos y cabeceras	Escaneo externo: solo 443 (y 80 que redirige); error 500 sin trazas	1 × 4 = 4 Bajo	La configuración se verifica antes de cada entrega
R16	Preventivo: tiempo de espera de 2 s, corte automático, modo degradado Correctivo: conciliación por el worker	Simular la caída del servicio → la app responde con mensaje claro y sigue atendiendo	3 × 2 = 6 Medio	La caída del tercero sigue ocurriendo (P 3), pero ya no tumba el sistema: solo impide confirmar reservas por un tiempo
R17	Preventivo: TLS con verificación de certificado, credencial de servicio, validación de esquema	Respuesta con campos inesperados → rechazada; certificado inválido → conexión rechazada	1 × 4 = 4 Bajo	Falsificar exige romper TLS y la credencial
R18	Preventivo: dos nodos, límites de tasa en proxy y app, caché de disponibilidad, paginación Detectivo: monitoreo de latencia y errores	Prueba de carga con 3.000 usuarios, con un nodo caído → errores < 1 %	2 × 3 = 6 Medio	Los picos siguen ocurriendo (P 2), pero con un nodo se atiende el 84 % del pico (3.7); I baja a degradación parcial
R19	Preventivo: réplica en espera, copias 3-2-1 con una inmutable o desconectada, parcheo · Correctivo: restauración probada	Simulacro de restauración en un entorno limpio → datos íntegros dentro del RTO	2 × 2 = 4 Bajo	El fallo puede ocurrir, pero se pierden como máximo 5 minutos de datos
R20	Preventivo: respuestas y tiempos uniformes, límites de tasa	Respuesta para cédula existente e inexistente →	2 × 2 = 4 Bajo	Enumerar exige muchas solicitudes, frenadas por el límite

ID	Controles propuestos	Verificación	Residual	Justificación del residual
		idéntica		
R21	Preventivo: requisito I14 eliminado, plazos de conservación (Parte 2), prohibición de ceder datos fuera de encargados con contrato	Revisión del diseño: ninguna integración ni exportación a terceros	1 × 5 = 5 Medio	La cesión no existe en el diseño; I se mantiene porque una cesión futura sin base seguiría siendo infracción grave
R22	Preventivo: cookies `HttpOnly`, `Secure` y `SameSite`, inactividad de 15 min, CSP, cerrar sesión en todos los dispositivos	Inspección de cookies e sesión inactiva 15 min → expira	1 × 3 = 3 Bajo	La sesión no es legible por scripts y caduca pronto

4.5 Resumen

Nivel	Inherente	Residual
Crítico (15–25)	10	0
Alto (10–14)	7	0
Medio (5–9)	5	9
Bajo (1–4)	0	13

Todos los residuales cumplen el criterio de aceptación (≤ 9). Los 9 medios restantes se aceptan con monitoreo, por dos razones:

- El impacto no puede bajar sin dejar de prestar el servicio: el sistema sigue tratando un dato de salud indirecto por lo tanto debe ser tomado en cuenta.
- La amenaza no se elimina desde el software: Existen amenazas externas como phishing, caídas de terceros o picos de demanda o se tiene un funcionario con acceso legítimo.

5. Relación con MITRE ATT&CK

Se cubren 17 de los 22 riesgos, los otros 5 no tienen técnica porque no describen a un adversario (fallos de terceros, concurrencia, decisiones del responsable), y no se fuerza una correspondencia.

5.1 Criterios

- Versión: ATT&CK Enterprise v20, publicada el 13-oct-2026 (versiones de ATT&CK). Desde la v19, la antigua táctica Defense Evasion se divide en Stealth (TA0005) y Defense Impairment (TA0112) (ATT&CK, abril 2026); por eso T1070 figura en Stealth.
- Alcance: solo técnicas aplicables a una aplicación web con base de datos y se excluyen las de equipos de usuario y Windows, porque no son superficie de este sistema.
- Fuentes de técnicas y mitigaciones: attack.mitre.org consulta del 29-oct-2026.

5.2 Técnicas del adversario

ID	Técnica o subtécnica	Táctica	Riesgos	Relación con el escenario
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance (TA0043)	R15	Escanea puertos, cabeceras y rutas en busca de modo depuración o API de Caddy expuesta
T1589	Gather Victim Identity Information	Reconnaissance (TA0043)	R06, R20	Obtiene cédula y fecha de nacimiento de la víctima, o enumera cédulas para saber quién es afiliado
T1598.003	Phishing for Information: Spearphishing Link	Reconnaissance (TA0043)	R09	Correo que imita al IESS para obtener credenciales
T1190	Exploit Public-Facing Application	Initial Access (TA0001)	R01, R12, R13, R15	Explota la aplicación expuesta: IDOR, inyección SQL o XSS, o un CVE del framework
T1078	Valid Accounts	Initial Access (TA0001)	R02, R03, R04	Opera con una cuenta legítima, robada o propia (insider), por lo que su actividad parece normal
T1566.002	Phishing: Spearphishing Link	Initial Access (TA0001)	R03, R09	Enlace a un sitio clonado dirigido a funcionarios o afiliados
T1195.001	Supply Chain Compromise: Compromise Software Dependencies and Development	Initial Access (TA0001)	R13	Paquete de Python o JavaScript comprometido incluido en la construcción

ID	Técnica o subtécnica	Táctica	Riesgos	Relación con el escenario
	Tools			
T1110.001 / .003 / .004	Brute Force: Password Guessing / Password Spraying / Credential Stuffing	Credential Access (TA0006)	R02	Adivinar contraseñas, probar una contraseña común en muchas cuentas o usar pares filtrados de otros servicios
T1111	Multi-Factor Authentication Interception	Credential Access (TA0006)	R03	Un proxy de phishing captura también el código TOTP en tiempo real
T1539	Steal Web Session Cookie	Credential Access (TA0006)	R22	Roba la cookie de sesión (equipo compartido o script inyectado) y actúa sin contraseña ni MFA
T1552.001	Unsecured Credentials: Credentials In Files	Credential Access (TA0006)	R10	Lee contraseñas o tokens escritos en archivos de registro
T1557	Adversary-in-the-Middle	Credential Access (TA0006)	R17	Se interpone entre la app y los servicios del IESS para leer o falsear respuestas
T1210	Exploitation of Remote Services	Lateral Movement (TA0008)	R14	Desde la red interna explota Valkey (p. ej., CVE-2025-67733)
T1213	Data from Information Repositories	Collection (TA0009)	R04	Un funcionario consulta masivamente turnos con su acceso legítimo
T1070	Indicator Removal	Stealth (TA0005)	R11	Borra o altera eventos de auditoría para ocultar su acceso
T1565.001	Data Manipulation: Stored Data Manipulation	Impact (TA0040)	R01, R11	Modifica o cancela turnos ajenos, o altera la auditoría
T1499.002 / .003	Endpoint Denial of Service: Service Exhaustion Flood / Application	Impact (TA0040)	R18	Satura el servicio o las operaciones costosas (búsqueda de disponibilidad) en la apertura

ID	Técnica o subtécnica	Táctica	Riesgos	Relación con el escenario
	Exhaustion Flood			de agendas
T1486	Data Encrypted for Impact	Impact (TA0040)	R19	Ransomware cifra la base de datos
T1490	Inhibit System Recovery	Impact (TA0040)	R19	Borra o cifra también las copias de respaldo alcanzables

5.3 Controles defensivos por técnica

Las mitigaciones son las que ATT&CK asocia a cada técnica. Las columnas de detección y respuesta añaden la regla y la acción concretas.

Técnica	Prevenir	Detectar	Responder
T1595.002	M1056 Pre-compromise: solo 443 expuesto, sin versión en cabeceras → R15	Patrones de escaneo en el registro de Caddy (muchas rutas 404 desde una IP)	Bloqueo temporal de la IP en el proxy
T1589	M1056 Pre-compromise: respuestas y tiempos uniformes; representación con consentimiento → R06, R20	Solicitudes de registro o recuperación con muchas cédulas distintas desde una IP	Límite de tasa más estricto tambien genera aviso al titular si alguien intentó representarlo
T1598.003, T1566.002	M1054 Software Configuration (SPF, DKIM, DMARC), M1017 User Training → R09	Reportes de correos falsos; informes DMARC	Pedir la retirada del dominio falso y genera un aviso a los afiliados
T1190	M1048 Application Isolation, M1050 Exploit Protection, M1051 Update Software, M1016 Vulnerability Scanning → R01, R12, R13	Ráfagas de 403/404 o 500 por usuario; hallazgos de ZAP	Corregir y desplegar sin corte y si hubo acceso a datos, notificar en 5 días (art. 43)
T1078	M1032 MFA, M1026 Privileged Account Management, M1018 User Account Management → R02, R03, R04	Inicio de sesión desde dispositivo o IP nuevos; funcionario fuera de su horario	Cerrar todas las sesiones de la cuenta y forzar cambio de credenciales
T1195.001	M1051 Update Software, M1016	`pip-audit` en cada	Revertir a la

Técnica	Prevenir	Detectar	Responder
	Vulnerability Scanning: dependencias fijadas con hash, `pip-audit`, HTMX servido localmente → R13	construcción; avisos de seguridad de Django	versión anterior y reconstruir
T1110.001 / .003 / .004	M1032 MFA, M1036 Account Use Policies, M1027 Password Policies → R02	Más de 5 fallos por cuenta o 20 por IP en 10 min; una misma contraseña probada en muchas cuentas	Espera progresiva automática y generar aviso al titular
T1111	M1017 User Training; MFA resistente a phishing (WebAuthn, documentada como extensión) → R03	Inicio exitoso con TOTP desde una IP o país nunca vistos	Revocar sesiones; reenrolar el TOTP
T1539	M1054 Software Configuration (cookies `HttpOnly`, `Secure`, `SameSite`), M1021 Restrict Web-Based Content (CSP), M1047 Audit → R22	Misma sesión usada desde dos IP o navegadores distintos	Invalidar la sesión en el servidor
T1552.001	M1022 Restrict File and Directory Permissions; registros sin secretos → R10	Prueba que busca patrones de token y contraseña en los registros	Rotar el secreto expuesto y purgar el registro
T1557	M1041 Encrypt Sensitive Information (TLS con verificación de certificado), validación de esquema → R17	Errores de certificado o respuestas que no cumplen el esquema	Corte automático de la integración; modo degradado
T1210	M1042 Disable or Remove Feature (scripting de Valkey bloqueado por ACL), M1030 Network Segmentation, M1051 Update Software → R14	Comandos denegados por ACL en el registro de Valkey	Aislar el contenedor y rotar su contraseña
T1213	M1018 User Account Management (alcance por establecimiento), M1047 Audit → R04	Volumen de consultas por funcionario por encima de su media	Suspender la cuenta y revisar la auditoría
T1070	M1029 Remote Data Storage (copia externa), M1022 permisos de solo anexado → R11	Verificación periódica de la cadena de hash; interrupción del flujo de eventos	Restaurar desde la copia externa; investigación
T1565.001	M1022 permisos mínimos en BD; autorización por objeto → R01, R11	Cancelaciones o cambios anómalos por cuenta; auditoría	Revertir desde la auditoría y notificar al titular

Técnica	Prevenir	Detectar	Responder
T1499.002 / .003	M1037 Filter Network Traffic (límites de tasa en el proxy) → R18	Latencia p95 y tasa de errores 5xx	Bloquear IP, activar la cola de espera
T1486, T1490	M1053 Data Backup (3-2-1 con copia inmutable) → R19	Monitoreo de integridad de archivos de la BD	Restaurar dentro del RTO de 1 h y notificar en 5 días (art. 43)

5.4 Riesgos sin técnica ATT&CK

Riesgo	Motivo	Referencia alternativa
R05 Acaparamiento de turnos con bots	Es abuso de la lógica de negocio, no una técnica de intrusión	OWASP Automated Threats to Web Applications (amenazas automatizadas sobre inventario)
R07 Doble reserva por concurrencia	Fallo de diseño sin adversario	—
R08 Datos de salud en notificaciones	Exposición creada por el requisito I09, no por un atacante	LOPDP art. 4 y 30
R16 Caída de los servicios del IESS	Falla externa no maliciosa	—
R21 Cesión de datos a un proveedor de IA	Decisión del propio responsable	LOPDP art. 33 y 68

5.5 Capa para ATT&CK Navigator

La capa marca las técnicas aplicables con su **riesgo residual** (de la sección 4.5) como puntuación, para visualizar la cobertura en el Navigator.

```
{
  "name": "Turnos IESS - riesgo residual",
  "domain": "enterprise-attack",
  "versions": { "attack": "20", "layer": "4.5" },
  "description": "Puntuación = riesgo residual P x I (Parte 4). Comentario = riesgo y
control.",
  "gradient": { "colors": ["#8ec843", "#ffe766", "#ff6666"], "minValue": 1,
"maxValue": 25 },
  "techniques": [
    { "techniqueID": "T1595.002", "score": 4, "comment": "R15: solo 443 expuesto, API
de Caddy deshabilitada" },
    { "techniqueID": "T1589", "score": 4, "comment": "R06, R20: respuestas uniformes,
representación con consentimiento" },
```

```
    { "techniqueID": "T1598.003", "score": 6, "comment": "R09: SPF/DKIM/DMARC, TOTP"
},
    { "techniqueID": "T1190", "score": 5, "comment": "R01, R12, R13: autorización por
objeto, ORM, pip-audit" },
    { "techniqueID": "T1078", "score": 8, "comment": "R02, R03, R04: TOTP, alcance,
auditoría" },
    { "techniqueID": "T1566.002", "score": 6, "comment": "R03, R09: TOTP,
capacitación" },
    { "techniqueID": "T1195.001", "score": 4, "comment": "R13: dependencias fijadas y
auditadas" },
    { "techniqueID": "T1110.001", "score": 8, "comment": "R02: espera progresiva,
TOTP" },
    { "techniqueID": "T1110.003", "score": 8, "comment": "R02: detección de spraying"
},
    { "techniqueID": "T1110.004", "score": 8, "comment": "R02: lista de contraseñas
filtradas" },
    { "techniqueID": "T1111", "score": 6, "comment": "R03: WebAuthn como extensión"
},
    { "techniqueID": "T1539", "score": 3, "comment": "R22: cookies
HttpOnly/Secure/SameSite" },
    { "techniqueID": "T1552.001", "score": 3, "comment": "R10: registros sin
secretos" },
    { "techniqueID": "T1557", "score": 4, "comment": "R17: TLS verificado, validación
de esquema" },
    { "techniqueID": "T1210", "score": 3, "comment": "R14: ACL sin scripting, red
interna" },
    { "techniqueID": "T1213", "score": 6, "comment": "R04: alcance y auditoría" },
    { "techniqueID": "T1070", "score": 4, "comment": "R11: auditoría solo anexado con
hash" },
    { "techniqueID": "T1565.001", "score": 5, "comment": "R01, R11: autorización por
objeto" },
    { "techniqueID": "T1499.002", "score": 6, "comment": "R18: límites de tasa, 2
nodos" },
    { "techniqueID": "T1499.003", "score": 6, "comment": "R18: caché y paginación" },
    { "techniqueID": "T1486", "score": 4, "comment": "R19: copia inmutable" },
    { "techniqueID": "T1490", "score": 4, "comment": "R19: copia desconectada" }
  ]
}
```